TASK 2

Phishing Awareness Training

How to spot, stop and report phishing attacks

CodeAlpha Cyber Security Internship

Submitted by: [Your Name] | Intern ID: [Your ID] | Date: [Date]

1. What is Phishing?

Phishing is a cyber attack in which a criminal pretends to be a trusted person or organization (a bank, your employer, a delivery company, a government office) to trick you into clicking a malicious link, opening an infected file, or revealing sensitive data such as passwords, OTPs, card numbers or personal details. It succeeds because it targets **people**, not software.

Why it matters

- Most data breaches begin with a human mistake such as a clicked link or a shared password.
- A single stolen password can give an attacker access to email, banking, cloud storage and company systems.
- Attacks are cheap to send in bulk and increasingly well written, including AI-generated messages with no spelling errors.

2. Types of Phishing

Type	How it works	Example
Email phishing	Mass emails impersonating a known brand	'Your account is suspended, verify now'
Spear phishing	Targeted at one person using personal/job details	Email appearing to be from your manager asking for a file
Whaling	Targets executives or finance heads	Fake CEO asking for an urgent wire transfer
Smishing	Phishing by SMS	'Parcel held, pay Rs. 20 customs fee: bit.ly/...'
Vishing	Phishing by phone call	Caller posing as bank staff asks for your OTP
Clone phishing	Copy of a real email with a malicious link swapped in	Resent 'invoice' with a different attachment
Fake websites	Look-alike login pages	paypa1.com or amaz0n-login.net
QR phishing (quishing)	Malicious QR code leads to a fake site	Fake parking-payment QR sticker

3. How to Recognize a Phishing Email

Red flag	What to look for
Sender address	Display name looks right but the real address is odd: support@micros0ft-security.com, or a free Gmail address pretending to be a company.
Urgency or threats	'Act within 24 hours or your account will be closed.' Pressure is designed to stop you thinking.
Generic greeting	'Dear customer' instead of your name (though spear phishing may use your name).
Suspicious links	Hover over the link: the real destination differs from the text. Watch for misspellings, extra words and odd domains.
Unexpected attachments	Unrequested .zip, .exe, .html, or Office files asking to 'Enable macros' or 'Enable content'.
Requests for secrets	Legitimate organizations never ask for your password, PIN or OTP by email, SMS or phone.
Too good to be true	Lottery wins, free gifts, surprise refunds, job offers with no interview.
Poor quality	Odd grammar, mismatched logos, strange formatting (not always present in modern attacks).

Anatomy of a phishing email (example)

```
From:    "PayPal Support" <service@paypal-secure-verify.com>   <-- not paypal.com
Subject: URGENT: Your account has been limited!
Body:    Dear Customer, we noticed unusual activity. You must verify
         your identity within 24 hours or your account will be closed.
         [ Verify My Account ]  -> http://paypa1-login.xyz/verify  <-- fake domain
         Attachment: Account_Details.html  <-- unexpected file
```

Problems: look-alike sender domain, urgency, generic greeting, mismatched link (paypa**1** uses the digit one), and a suspicious attachment.

4. Recognizing Fake Websites

- **Check the full domain.** In https://login.bank.com.evil.site the real domain is **evil.site**.
- **HTTPS is not proof of safety.** Attackers also get free certificates. The padlock only means the connection is encrypted.
- Look for typos, look-alike characters (rn vs m, 0 vs o, l vs I) and unusual top-level domains.
- Be wary of pages that ask for far more data than normal (card PIN, full ID, OTP).
- Type the address yourself or use your saved bookmark instead of clicking links in messages.
- Use a password manager: it will not auto-fill credentials on a domain that does not match.

5. Social Engineering Tactics

Phishing works by exploiting human psychology. Attackers combine the following levers:

Tactic	Psychology	Example
Authority	We obey bosses, police, banks	'This is the CEO, send the payroll file now.'
Urgency / scarcity	Fear of loss rushes decisions	'Only 2 hours left to claim your refund.'
Fear	Panic overrides caution	'Suspicious login detected - secure your account.'
Greed / curiosity	Rewards and gossip lower guard	'You have won a prize', 'See who viewed your profile'
Trust / familiarity	Messages from 'friends' feel safe	Hacked friend's account sends a link
Helpfulness	People want to help	'I am new and locked out, can you share the VPN password?'
Pretexting	A made-up story builds credibility	Fake IT support calling about a 'virus on your PC'

Rule of thumb: **if a message makes you feel rushed, scared or excited, stop and verify.**

6. Real-World Examples

Google and Facebook invoice scam (2013-2015). A Lithuanian fraudster sent fake invoices from a company impersonating a real hardware supplier, and the two companies paid over US$100 million in total before it was detected. Lesson: verify payment-detail changes through a second channel.

RSA SecurID breach (2011). Employees received a spear-phishing email titled '2011 Recruitment Plan' with an Excel attachment containing an exploit. It led to the compromise of sensitive authentication data. Lesson: even security companies fall for targeted lures.

Twitter hack (2020). Attackers phoned employees (vishing) pretending to be internal IT, obtained credentials, and took over high-profile accounts to run a Bitcoin scam. Lesson: voice calls can be phishing

too.

Delivery-fee SMS scams (ongoing). Texts claiming a parcel is held ask for a small 'fee', capturing card details. Lesson: couriers do not ask for card payment through random links.

7. Best Practices: How to Stay Safe

- **Stop, think, verify.** Contact the organization using the number on its official website, not the one in the message.
- **Never share** passwords, OTPs, PINs or CVV with anyone, ever.
- **Enable multi-factor authentication (MFA)** on email, banking and social media. Prefer an authenticator app or hardware key over SMS.
- **Use a password manager** and a unique password for every account.
- **Keep software updated:** OS, browser, antivirus and email filters.
- **Do not open unexpected attachments;** never enable macros on files from unknown senders.
- **Hover before you click** and preview the link destination.
- **Be careful with QR codes** in public places and check the URL they open.
- **Limit what you share** on social media: attackers use it to craft convincing spear-phishing.
- **Report it.** Forward to your IT/security team or your provider's phishing report address.

8. What To Do If You Clicked

Step	Action
1	Disconnect the device from the network if you opened a file or installed anything.
2	Change the password of the affected account immediately (and anywhere you reused it) from a clean device.
3	Enable or reset MFA and sign out all active sessions.
4	Run an antivirus/anti-malware scan.
5	Alert your IT team or bank so they can block cards or monitor activity.
6	Report the incident (in India: cybercrime.gov.in or helpline 1930).

9. Interactive Quiz

Choose the best answer for each question. Answers are on the next page - no peeking!

Q1. You get an email from 'IT Support' saying your mailbox is full and asks you to log in via a link. What should you do?

A) Click the link quickly before the mailbox closes

B) Reply with your password so IT can fix it

C) Do not click; check with IT using a known contact method

D) Forward it to colleagues as a warning with the link

Q2. Which link is most likely legitimate for Amazon?

A) amazon.account-verify.com

B) www.amaz0n.com

C) www.amazon.com/orders

D) amazon-support.xyz

Q3. A website has a padlock and https://. Does this mean it is safe?

A) Yes, always

B) No, it only means the connection is encrypted, not that the site is trustworthy

C) Yes, if the padlock is green

D) Only on mobile

Q4. Your 'bank' calls and asks for the OTP just sent to your phone to 'cancel a fraudulent transaction'. You should:

A) Give the OTP to protect your money

B) Give half the OTP

C) Hang up and call the bank on the number printed on your card

D) Ask the caller to prove who they are by describing your account

Q5. Which is NOT a common sign of phishing?

A) Sense of urgency

B) Mismatch between link text and real URL

C) Message addressed to you by name with no links or requests

D) Request for credentials

Q6. Your CEO emails you to urgently buy gift cards and send the codes. This is likely:

A) A legitimate request

B) Whaling / business email compromise

C) A system notification

D) Clone phishing of a newsletter

Q7. You clicked a suspicious link and entered your password. What is the FIRST thing to do?

A) Wait and see what happens

B) Change that password from a safe device and report it

C) Delete the email and ignore it

D) Restart your computer

Q8. Which MFA method is generally strongest against phishing?

A) SMS code

B) Security question

C) Hardware security key / passkey

D) Email code

Quiz Answers

Q	Answer	Explanation
1	C	Urgent mailbox warnings are a classic lure. Verify using an independent, known channel.
2	C	Only amazon.com is the real domain. Others use extra words, digits, or odd TLDs.
3	B	Attackers can obtain valid HTTPS certificates. Check the domain itself.
4	C	Banks never ask for OTPs. Call back using an official number.
5	C	A personalized, benign message with no link or request is not a typical red flag by itself. A, B, D are all classic signs.
6	B	Gift card/wire requests from 'executives' are classic business email compromise.
7	B	Act fast: change the password, enable MFA, report. Reusing that password elsewhere? Change those too.
8	C	Hardware keys and passkeys are bound to the real site so they will not work on a fake page.

Scoring: 7-8 Phishing Pro | 5-6 Good, keep practicing | below 5 Review the red-flags section again.

Spot-the-Phish Exercise

Look at each message and decide: **Legit** or **Phish**? (Answers below)

- 1. SMS: 'Your SBI YONO account is blocked. Update KYC now: http://sbi-kyc-update.in.net'
- 2. Email from noreply@github.com about a new sign-in, with no link, telling you to check security settings on github.com yourself.
- 3. WhatsApp from an unknown number: 'Hi, I am your new HR. Please download this APK to see your salary slip.'

Answers: 1 = Phish (fake domain, urgency). 2 = Likely legit (known sender, no link, you verify yourself). 3 = Phish (unknown sender, APK install).

10. Quick Reference Checklist

Before you click, ask yourself
Do I know the sender, and is the address exactly right?
Was I expecting this message?
Is it rushing or scaring me?
Does the link destination match what it claims?
Is it asking for secrets or money?
Can I confirm through another channel?

Summary: **Stop. Think. Verify. Report.**